An official website of the United States government Here's how you know

America's Cyber Defense Agency
NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Archived Content

In an effort to keep CISA.gov current, the archive contains outdated information that may not reflect current policy or programs.

ICS MEDICAL ADVISORY

Baxter Sigma Spectrum Infusion Pumps (Update B)

Last Revised: August 11, 2022 **Alert Code:** ICSMA-20-170-04

1. EXECUTIVE SUMMARY

- **CVSS v3 8.6**
- ATTENTION: Exploitable remotely/low attack complexity
- Vendor: Baxter
- Equipment: Sigma Spectrum Infusion Pumps
- Vulnerabilities: Use of Hard-coded Password, Cleartext Transmission of Sensitive Data, Incorrect Permission Assignment for Critical Resource, Operation on a Resource After Expiration or Release

2. UPDATE INFORMATION

This updated advisory is a follow-up to the original advisory titled ICSA-20-170-04 Sigma Spectrum Infusion Pumps (Update A) that was published June 23, 2020, on the ICS webpage on cisa.gov/ics. <https://www.cisa.gov.ics>

3. RISK EVALUATION

Successful exploitation of these vulnerabilities could result in access to sensitive data, alteration of system configuration, and impact to system availability.

4. TECHNICAL DETAILS

4.1 AFFECTED PRODUCTS

The following versions of Sigma Spectrum Infusion systems, are affected:

- Sigma Spectrum v6.x model 35700BAX
- Baxter Spectrum v8.x model 35700BAX2

--------- Begin Update B Part 1 of 6 ---------

- Baxter Spectrum v9.x model 35700BAX3
- Sigma Spectrum LVP v6.x with Wireless Battery Modules v9, v11, v13, v14, v15, v16, v16D38, v17, v17D19, v20D29 to v20D32, and v22D24 to v22D28
- Baxter Spectrum LVP v8.x with Wireless Battery Modules v17, v17D19, v20D29 to v20D32, and v22D24 to v22D28
- Baxter Spectrum LVP v9.x with Wireless Battery Module v22D19 to v22D28

--------- End Update B Part 1 of 6 ---------

4.2 VULNERABILITY OVERVIEW

4.2.1 USE OF HARD-CODED PASSWORD CWE-259

<https://cwe.mitre.org/data/definitions/259.html>

Sigma Spectrum Infusion System Version(s) 6.x (model 35700BAX) and Baxter Spectrum Infusion System Version(s) 8.x (model 35700BAX2) contain hard-coded passwords which, when physically entered on the keypad, provide access to biomedical menus that include device settings, view of calibration values, and network configuration of the Sigma Spectrum Wireless Battery Module (WBM) if installed.

CVE-2020-12039 has been assigned to this vulnerability. A CVSS v3 base score of 4.3 has been calculated; the CVSS vector string is (AV:P/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:p/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:l>).

4.2.2 CLEARTEXT TRANSMISSION OF SENSITIVE DATA CWE-319

<https://cwe.mitre.org/data/definitions/319.html>

Sigma Spectrum Infusion System Version(s) 6.x (model 35700BAX) and Baxter Spectrum Infusion System Version(s) 8.x (model 35700BAX2) at the application layer uses an unauthenticated clear-text communication channel to send and receive system status and operational data. This could allow an attacker that has circumvented network security measures to view sensitive non-private data or to perform a man-in-the-middle attack.

CVE-2020-12040 has been assigned to this vulnerability. A CVSS v3 base score of 7.3 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:l>).

4.2.3 USE OF HARD CODED PASSWORD CWE-259 <https://cwe.mitre.org/data/definitions/259.html>

--------- Begin Update B Part 2 of 6 ---------

The Baxter Spectrum WBM (v9, v11, v13, v14, v15, v16, v16D38, v17, v17D19, v20D29 to v20D32, and v22D19 to v22D28) operates a Telnet service with hard-coded credentials when connected to specific SSIDs.

--------- End Update B Part 2 of 6 ---------

CVE-2020-12045 has been assigned to this vulnerability. A CVSS v3 base score of 8.6 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:h>).

4.2.4 INCORRECT PERMISSION ASSIGNMENT FOR CRITICAL RESOURCE CWE-732

<https://cwe.mitre.org/data/definitions/732.html>

--------- Begin Update B Part 3 of 6 ---------

The Baxter Spectrum WBM (v9, v11, v13, v14, v15, v16, v16D38, v17, v17D19, v20D29 to v20D32, and v22D19 to v22D28) Telnet Command-Line Interface grants access to sensitive data stored on the WBM that permits temporary configuration changes to network settings of the WBM. This access allows the WBM to be rebooted. Temporary configuration changes to network settings are removed upon reboot.

--------- End Update B Part 3 of 6 ---------

CVE-2020-12041 has been assigned to this vulnerability. A CVSS v3 base score of 8.6 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:h>).

4.2.5 USE OF HARD-CODED PASSWORD CWE-259

<https://cwe.mitre.org/data/definitions/259.html>

--------- Begin Update B Part 4 of 6 ---------

The factor-default wireless configuration of the Baxter Spectrum WBM (v17, v17D19, v20D29 to v20D32, and v22D19 to v22D28) enables File Transfer Protocol (FTP) service with hard-coded credentials.

--------- End Update B Part 4 of 6 ---------

CVE-2020-12047 has been assigned to this vulnerability. A CVSS v3 base score of 7.3 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:l>).

4.2.6 OPERATION ON A RESOURCE AFTER EXPIRATION OR RELEASE CWE-672

<https://cwe.mitre.org/data/definitions/672.html>

--------- Begin Update B Part 5 of 6 ---------

When configured for wireless networking, the Baxter Spectrum WBM (v17, v17D19, v20D29 to v20D32, and v22D19 to v22D28) enables FTP service operating on the WBM to remain operational until the WBM is rebooted.

--------- End Update B Part 5 of 6 ---------

CVE-2020-12043 has been assigned to this vulnerability. A CVSS v3 base score of 7.3 has been calculated; the CVSS vector string is (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:l/pr:n/ui:n/s:u/c:l/i:l/a:l>).

4.3 BACKGROUND

- **CRITICAL INFRASTRUCTURE SECTORS:** Healthcare and Public Health
- **COUNTRIES/AREAS DEPLOYED:** United States
- **COMPANY HEADQUARTERS LOCATION:** United States

4.4 RESEARCHER

Baxter Healthcare has reported these vulnerabilities to CISA.

5. MITIGATIONS

Baxter recommends ensuring appropriate physical controls within user environments to protect against unauthorized access to devices.

Baxter recommends isolating the Spectrum Infusion Systems to its own network VLAN to segregate the system from other hospital systems, and reduce the probability that a threat actor could execute an adjacent attack such as a MiTM attack against the system to observe clear-text communications.

--------- Begin Update B Part 6 of 6 ---------

Baxter recommends using the strongest available wireless network security protocols (e.g., WPA2, EAP-TLS, etc.) to provide authentication and encryption of wireless data sent to and from the Spectrum Infusion System.

--------- End Update B Part 6 of 6 ---------

Users should ensure the WBM is rebooted after configuration for their network(s) by removing the WBM from the rear of the Spectrum device for 10-15 seconds, and then re-attaching the WBM.

Users should always monitor for and/or block unexpected traffic, such as FTP, at network boundaries into the Spectrum-specific VLAN.

As a last resort, users may disable wireless operation of the pump. The Spectrum Infusion System was designed to operate without network access. This action would impact an organization's ability to rapidly deploy drug library (formulary) updates to their pumps.

For additional information please see the Baxter Product Security Bulletin <https://www.baxter.com/product-security#additionalresources>.

CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability. Specifically, users should:

- Minimize network exposure for all control system devices and/or systems, and ensure they are not accessible from the Internet <https://www.cisa.gov/uscert/ics/alerts/ics-alert-10-301-01>.
- Locate control system networks and remote devices behind firewalls and isolate them from the business network.
- When remote access is required, use secure methods, such as Virtual Private Networks (VPNs), recognizing VPNs may have vulnerabilities and should be updated to the most current version available. Also recognize VPN is only as secure as its connected devices.

CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures.

CISA also provides a section for control systems security recommended practices <https://www.cisa.gov/uscert/ics/recommended-practices> on the ICS webpage on cisa.gov <https://www.cisa.gov/uscert/ics>. Several recommended practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies <https://www.cisa.gov/uscert/sites/default/files/recommended_practices/nccic_ics-cert_defense_in_depth_2016_s508c.pdf>.

Additional mitigation guidance and recommended practices are publicly available on the ICS webpage on cisa.gov <https://www.cisa.gov/uscert/ics> in the Technical Information Paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies <https://www.cisa.gov/uscert/ics/tips/ics-tip-12-146-01b>.

Organizations observing any suspected malicious activity should follow their established internal procedures and report their findings to CISA for tracking and correlation against other incidents.

This product is provided subject to this Notification </notification> and this Privacy & Use </privacy-policy> policy.

Vendor

- Baxter

Please share your thoughts

We recently updated our anonymous product survey; we welcome your feedback.

Return to top

Topics </topics> **Spotlight** </spotlight> **Resources & Tools** </resources-tools>

News & Events </news-events> **Careers** </careers> **About** </about>

CISA Central

1-844-Say-CISA contact@cisa.dhs.gov

An official website of the U.S. Department of Homeland Security